TECHNICAL DETAIL

Title	Privilege Escalation via Role Parameter Manipulation during Registration
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/register
Severity	**High**
CVSS Score	**8.8** **CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H**
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

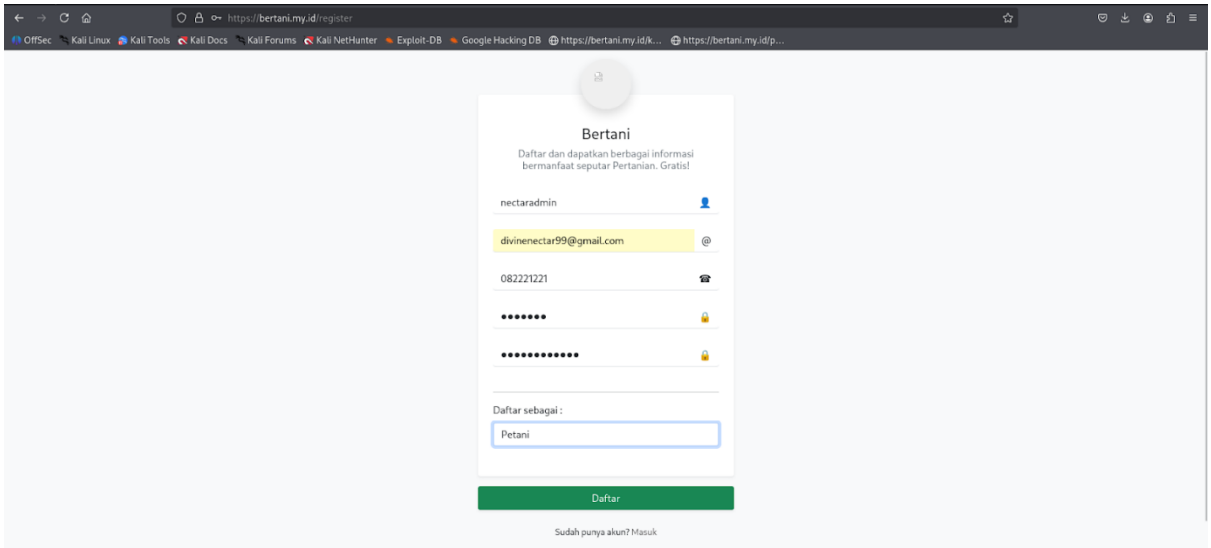
Ditemukan kerentanan Broken Access Control yang sangat kritis pada fungsi pendaftaran pengguna. Aplikasi mengandalkan parameter input role_name dari sisi klien yang dapat dimanipulasi melalui alat Burp Suite. Hal ini memungkinkan pendaftar baru untuk menetapkan hak akses sebagai Admin secara mandiri, yang memberikan kontrol penuh atas panel administrasi aplikasi, manajemen data pengguna, serta pengelolaan konten publik., data pengguna, dan konten publik.

STEPS TO REPRODUCE

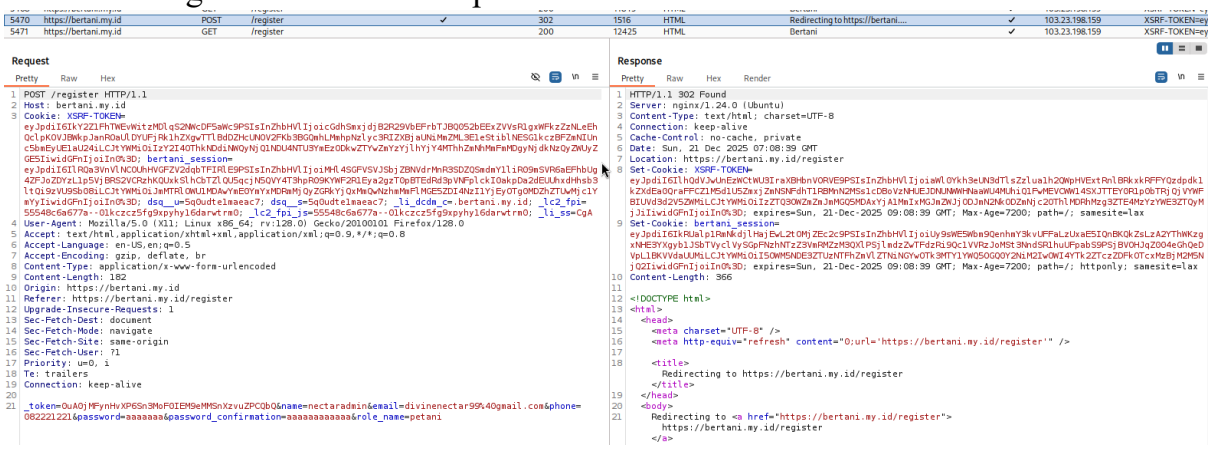
1. Nyalakan Proxy sesuaikan dengan port BurpSuite

2. Aktifkan fitur Intercept pada Burp Suite .

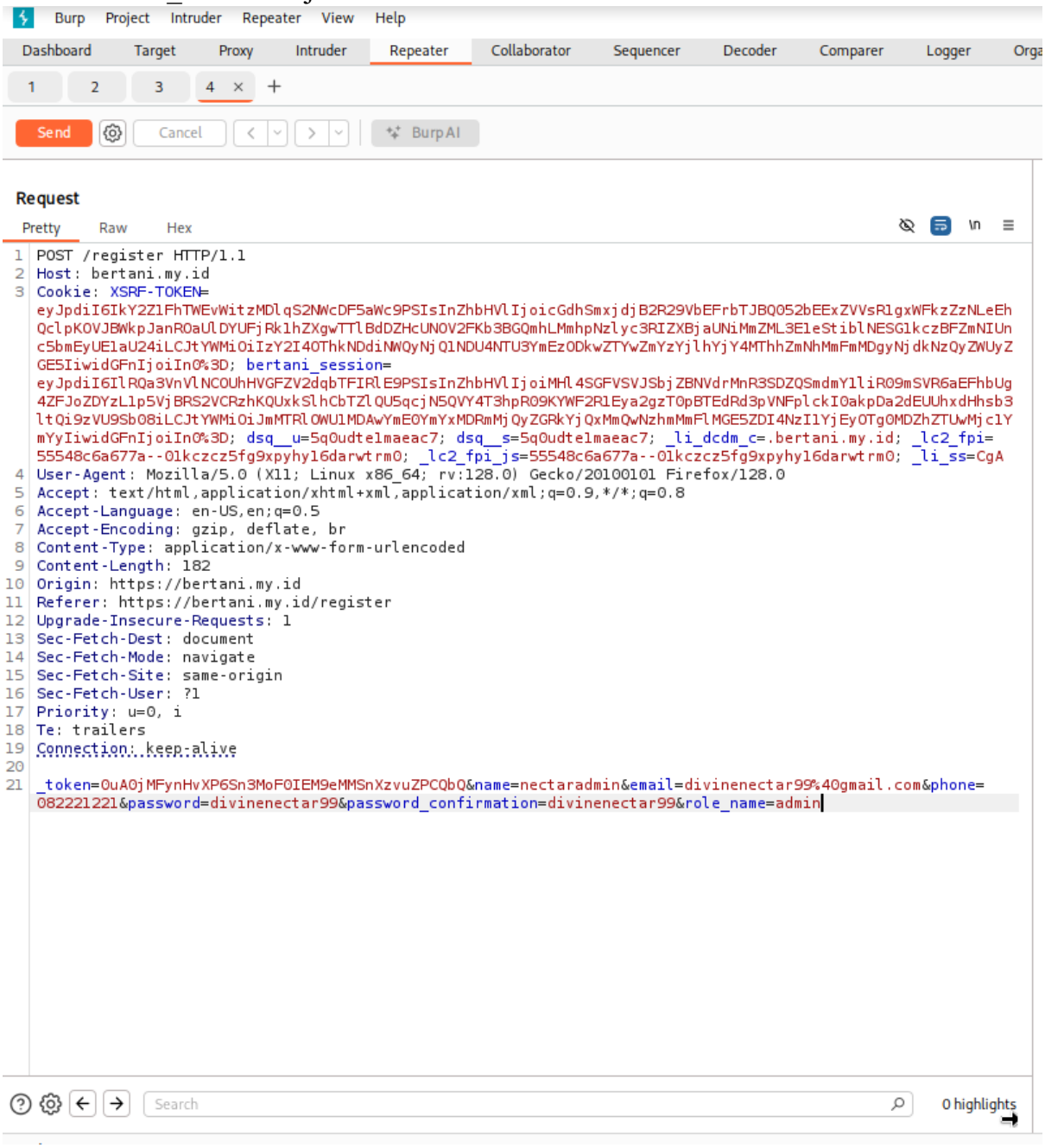
3. Masuk Ke halaman https://bertani.my.id/register lalu masukan data anda tetapi password harus salah



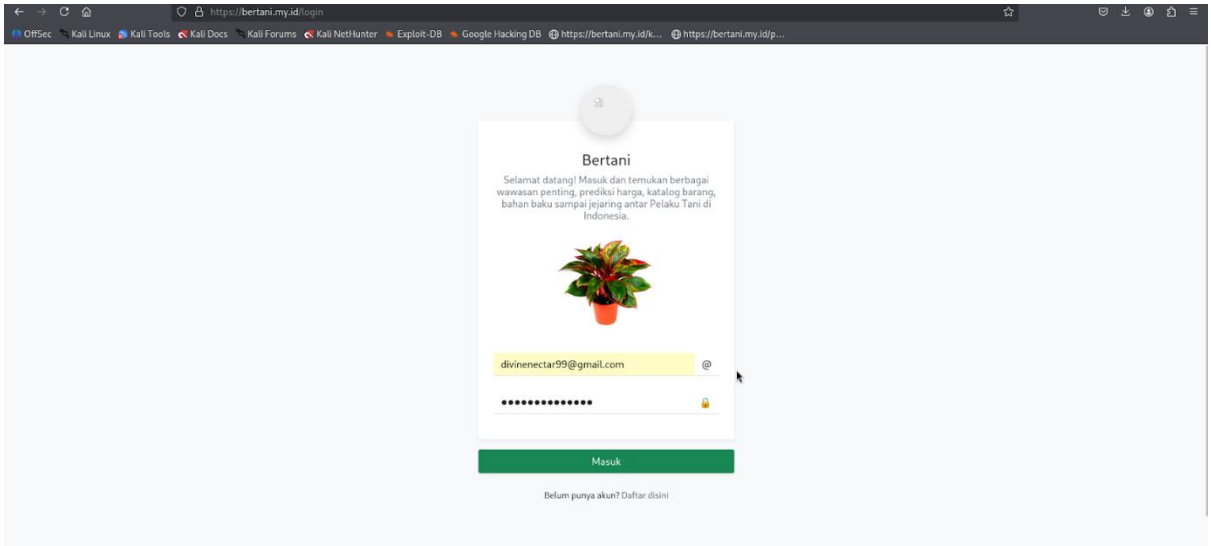
4. Cari Post /register lalu send ke repeater.



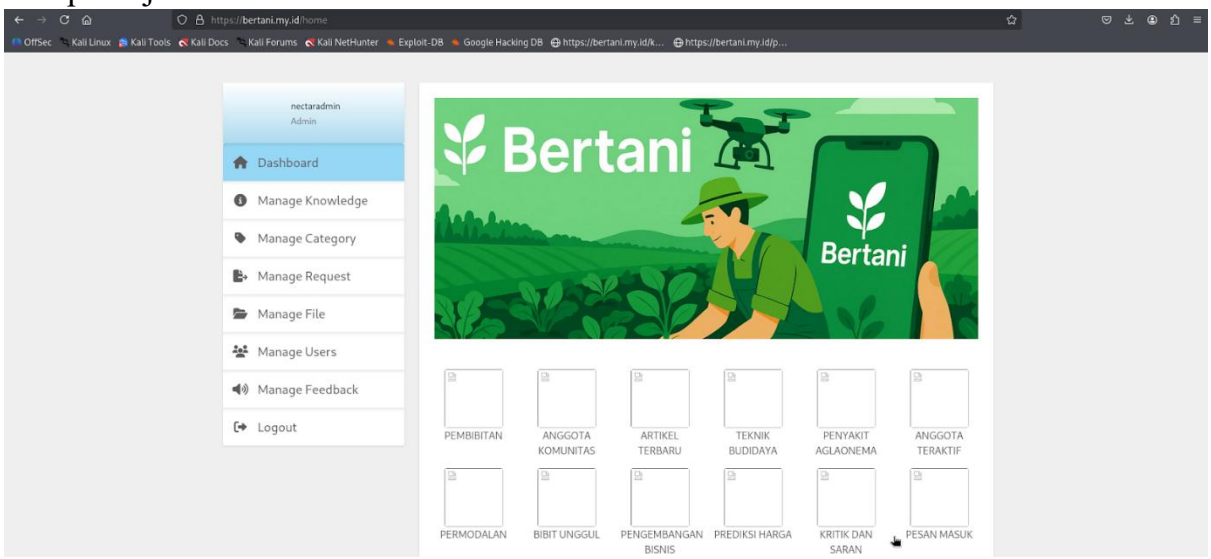
5. Pada bagian _token= ubah password dan password_confirmation agar sama lalu ubah role_name menjadi admin setelah itu tekan send



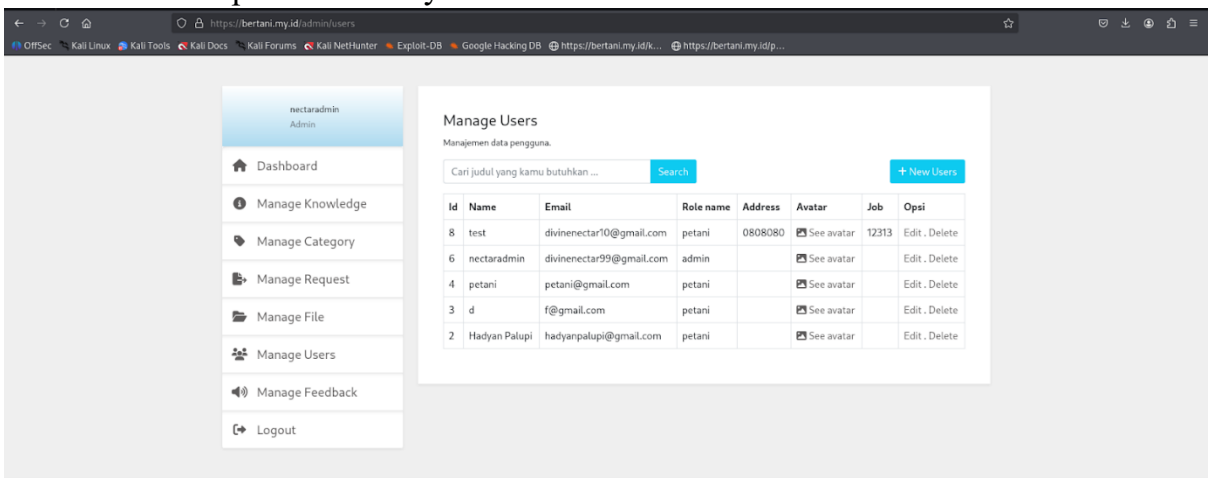
6. Masuk ke URL https://bertani.my.id/login dan masuk pakai akun yang sudah di daftarkan sebelumnya



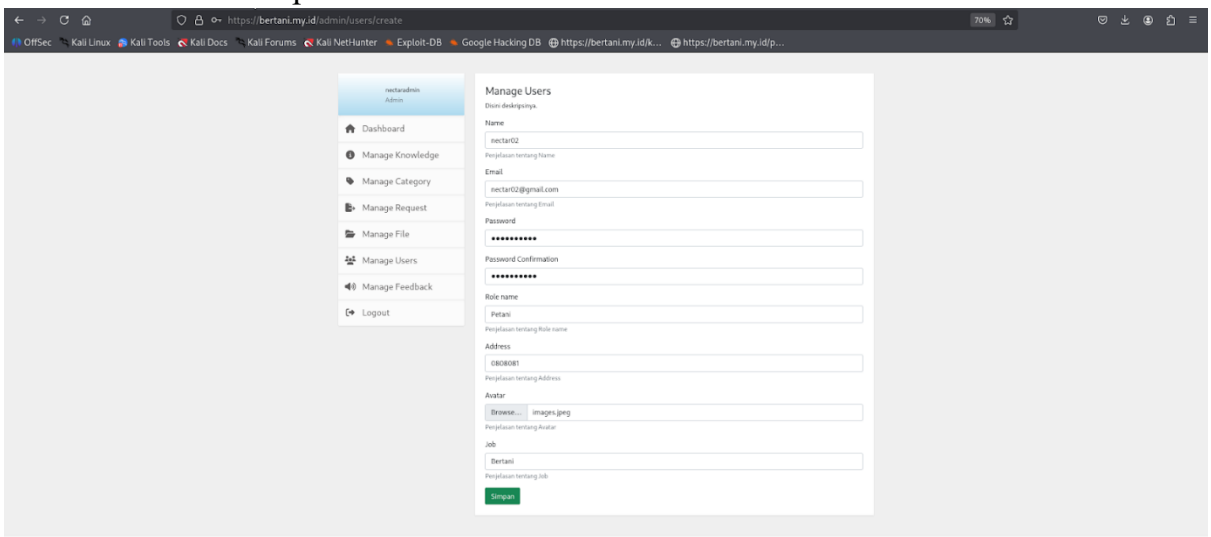
7. Tampilan jika berhasil masuk



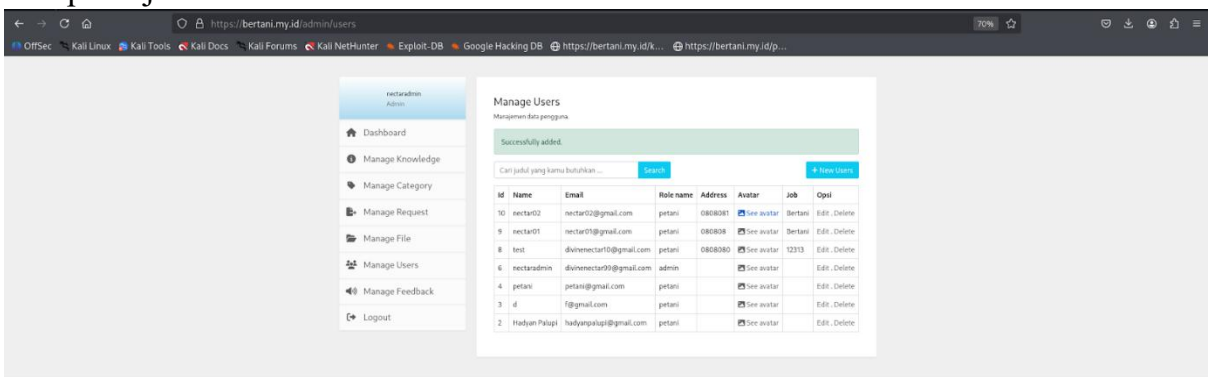
8. Masuk ke url https://bertani.my.id/admin/users dan tekan new users



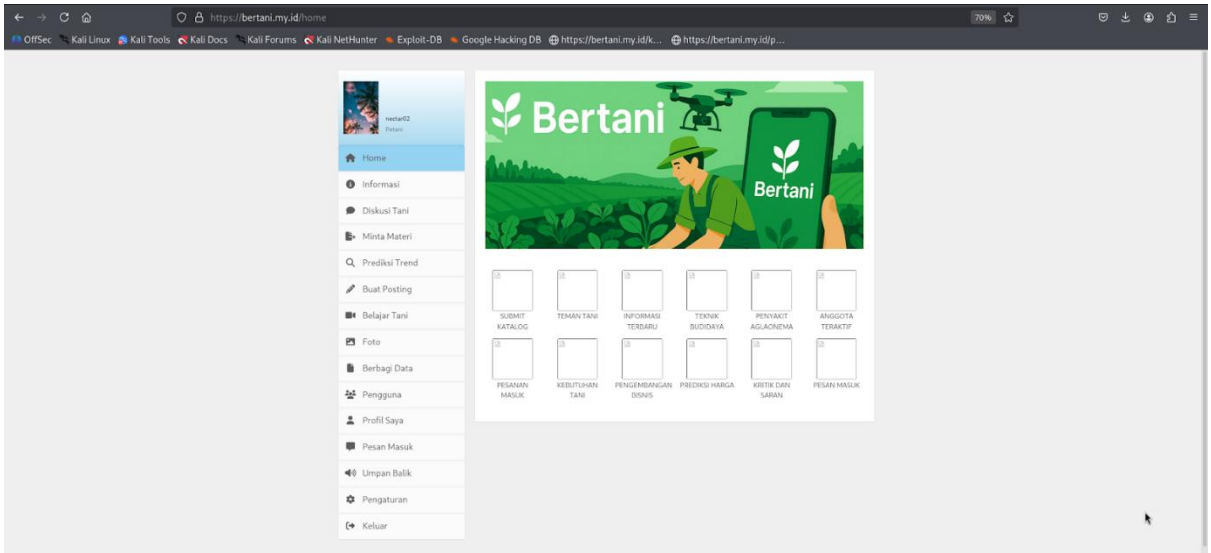
9. Lalu isi data dan simpan



10. Tampilan jika berhasil



11. Bukti user baru berhasil dibuat



EXPECTED RESULT

1. Sistem seharusnya hanya menerima dan memproses pilihan peran (*role*) yang diperuntukkan bagi publik (seperti 'petani' atau 'pedagang').
2. Peran 'admin' tidak boleh diterima atau diproses melalui formulir pendaftaran publik, terlepas dari manipulasi parameter di sisi klien.
3. Sisi server harus memastikan pendaftaran peran di luar daftar yang diizinkan akan ditolak secara otomatis.

ACTUAL RESULT

Aplikasi menerima dan memproses parameter role_name langsung dari input pendaftaran tanpa validasi otoritas di sisi server. Hal ini menyebabkan pendaftar dapat mengubah peran mereka menjadi 'admin' melalui manipulasi permintaan, sehingga berhasil mendapatkan akses ke dashboard administrator dan kontrol penuh atas data pengguna lain.

IMPACT

1.Total System Compromise: Penyerang mendapatkan hak administratif penuh.

2.Data Breach: Penyerang dapat melihat, menambah, mengedit, atau menghapus seluruh data pengguna di sistem.

3.Content Manipulation: Penyerang dapat mengubah konten forum, postingan, dan katalog milik pengguna lain.

4.Privilege Escalation: Pengguna tingkat rendah dapat menaikkan hak aksesnya melampaui batas yang ditentukan.

RECOMMENDATION

1.Server-Side Role Assignment: Hapus parameter role_name dari form pendaftaran publik. Tetapkan peran secara hardcoded di sisi server sebagai 'user' atau 'petani' saat proses registrasi.

2.Access Control List (ACL): Pastikan hanya admin sah yang dapat mengubah peran pengguna melalui panel admin yang telah terproteksi.

3.Principle of Least Privilege: Jangan pernah mempercayai input dari sisi klien untuk fungsi-fungsi sensitif yang berkaitan dengan otorisasi dan hak akses.

REFERENCES

1. OWASP - Mass Assignment Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
2. CWE-269: Improper Privilege Management: https://cwe.mitre.org/data/definitions/269.html
3. OWASP API Security - Broken Object Level Authorization (BOLA/Mass Assignment): https://owasp.org/www-project-api-security/